

1 Giới thiệu

1.1 Vấn đề

Trong những năm gần đây, việc ứng dụng tác tử thông minh và hệ thống đa tác tử vào bài toán dò tìm lỗ hổng bảo mật đang thu hút sự quan tâm của cả cộng đồng học thuật lẫn công nghiệp. Tuy nhiên, một trong những thách thức chính vẫn là xác thực tính tin cậy của các lỗ hổng do tác tử báo cáo. Trên thực tế, tác tử có thể đưa ra cảnh báo sai, và những trường hợp như vậy thường cần đến sự can thiệp thủ công để kiểm chứng trước khi dữ liệu được đưa vào huấn luyện.

Nghiên cứu của chúng tôi tiếp cận vấn đề này bằng cách kết hợp mô hình kinh tế học mật mã với hệ thống đa tác tử, nhằm điều chỉnh động lực hành vi của các tác tử. Cách tiếp cận này hướng tới việc để mỗi tác tử trong mạng lưới có thể tự đánh giá, kiểm chứng chéo các báo cáo lỗ hổng, đồng thời thực thi cơ chế bác bỏ đối với các báo cáo sai lệch mà không cần sự can thiệp trực tiếp từ con người.

1.2 Phát biểu bài toán

Mỗi thiết bị hoặc hệ thống phần mềm đều có thể tồn tại các lỗ hổng bảo mật ở những mức độ khác nhau. Bài toán đặt ra là làm thế nào để tự động phát hiện và báo cáo các lỗ hổng này giữa nhiều thiết bị, đồng thời tích hợp quá trình đó vào một cơ chế học máy liên kết.

Trong mô hình đề xuất, mỗi thiết bị duy trì một tập hợp tác tử nội bộ, đảm nhiệm việc quét, phát hiện lỗ hổng và gửi báo cáo về máy chủ trung tâm. Tại máy chủ, các báo cáo được cập nhật vào blockchain dưới dạng một máy trạng thái hữu hạn, cho phép lưu trữ bất biến và truy vết về sau. Kết quả phân xử liên quan đến tính hợp lệ của lỗ hổng được ghi nhận ngược lại lên blockchain, qua đó cung cấp nguồn dữ liệu có kiểm chứng cho nền tảng Flower tiến hành huấn luyện lại các mô hình.

Hệ thống được thiết kế để có thể triển khai linh hoạt. Một thiết bị có thể duy trì nhiều tác tử, hoặc các doanh nghiệp có thể vận hành nhiều hệ thống tác tử với cấu hình khác nhau. Một số nghiên cứu trước đây đã chỉ ra rằng khi số lượng tác tử tham gia mạng lưới tăng lên, độ chính xác tổng thể của hệ thống có xu hướng được cải thiện.

Ví dụ, trong một môi trường doanh nghiệp sở hữu cả phần mềm mã nguồn mở lẫn mã nguồn đóng, các tác tử hoạt động trực tiếp trên những thiết bị vận hành phần mềm đó. Chúng tự động trích xuất thông tin, gửi dữ liệu về máy chủ để cập nhật, và cảnh báo cho mạng lưới khi phát hiện các biến động bảo mật.

2 Cơ sở lý thuyết

2.1 Blockchain

Blockchain là công nghệ sổ cái phân tán cho phép ghi nhận và giám sát giao dịch một cách minh bạch. Nhờ đặc tính bất biến, dữ liệu sau khi được xác nhận trên blockchain khó có thể bị xóa bỏ hay làm giả. Trong phạm vi nghiên cứu này, chuỗi khối đóng vai trò là hạ tầng lưu trữ trạng thái của các lỗ hổng bảo mật, từ đó tạo lập nguồn dữ liệu có thể kiểm chứng phục vụ cho quá trình học máy liên kết.

2.2 Trò chơi phân xử

Trò chơi phân xử là một cơ chế kinh tế học được sử dụng phổ biến trên layer 2 của Ethereum, tiêu biểu như Optimism hoặc UMA. Theo nguyên lý này, mọi giao dịch hoặc báo cáo ban đầu được xem là hợp lệ, với điều kiện bên đề xuất đính kèm một khoản tài sản thế chấp.

Khi áp dụng vào bài toán tác tử tìm lỗ hổng bảo mật, hệ thống luôn đối mặt với rủi ro về tính chính xác của báo cáo và chi phí xác thực thủ công. Việc sử dụng trò chơi phân xử mang lại hai lợi ích chính. Thứ nhất là tối ưu hóa bằng thông xử lý ở giai đoạn nhập liệu ban đầu. Thứ hai là thiết lập cơ chế phát sóng, cho phép các tác tử khác trong mạng lưới nắm bắt ngay trạng thái của một lỗ hổng được giả định là hợp lệ, qua đó giảm thời gian chờ kiểm duyệt trước khi đưa vào huấn luyện.

Đánh đổi của cơ chế này là hệ thống chấp nhận rủi ro một số báo cáo sai có thể tồn tại trong thời gian ngắn và được đưa vào mô hình học máy liên kết trước khi bị các tác tử khác phát hiện và thách thức.

2.3 Hệ thống đa tác tử

Hệ thống đa tác tử là một lĩnh vực nghiên cứu lâu đời, với các bài toán mô phỏng tự nhiên tiêu biểu như sự phối hợp chuyển động của đàn cá. Kế thừa nguyên lý tương tác phi tập trung của hệ thống đa tác tử, nghiên cứu này tích hợp thêm các mô hình ngôn ngữ lớn nhằm nâng cao năng lực suy luận và phân tích của từng tác tử.

Trong hệ thống, các tác tử hoạt động dựa trên một tập quy tắc cơ sở và hướng tới mục tiêu tối ưu hóa điểm số nhận được từ quá trình đánh giá lỗ hổng. Những tác tử liên tục đưa ra báo cáo sai hoặc có điểm tín nhiệm thấp sẽ phải chịu các hình phạt, chẳng hạn như bị giới hạn tần suất gửi yêu cầu lên máy chủ.

2.4 Học máy liên kết

Học máy liên kết cho phép tổng hợp tri thức từ nhiều thiết bị độc lập để xây dựng một mô hình tối ưu mà không cần chia sẻ dữ liệu gốc. Trong mô hình đề xuất, các thiết bị cục bộ thực thi các mã nguồn chứa tác tử.

Các tác tử này tiến hành phát hiện và gửi báo cáo về máy chủ trung tâm – nơi diễn ra quá trình vận hành trò chơi phân xử. Sau khi dữ liệu được xác thực và tổng hợp thông qua các phiên phân xử, framework Flower tiếp nhận nguồn dữ liệu này để huấn luyện, sau đó phân phối ngược lại các tham số mô hình cho các tác tử nội bộ.

3 Thiết kế trò chơi

Mỗi thiết bị sẽ có một nhóm tác tử với số lượng tối thiểu là 1 và một máy chủ trung tâm để thực hiện phân xử tính hợp lệ của các lỗ hổng.

4 Mô phỏng

Trong môi trường mô phỏng, mỗi thiết bị thành viên chứa mã nguồn của các phần mềm mục tiêu. OFMIS tiến hành dò quét tự động vào các thư mục này. Khi phát hiện bất thường, tác tử tổng hợp và sinh ra một đoạn mã khai thác nhằm chứng minh sự tồn tại và trạng thái của lỗ hổng.

Các báo cáo và mã khai thác sau đó được đóng gói và đẩy lên máy chủ trung tâm. Các tác tử hoạt động trên những thiết bị khác trong mạng lưới có thể chủ động tải các gói dữ liệu này về môi trường cục bộ để tự động chạy kiểm thử và xác minh.

Mọi vòng đời của một lỗ hổng đều gắn liền với mã khai thác và trạng thái đồng thuận hiện hành. Tương tự cơ chế đồng bộ của blockchain, bất kỳ thay đổi trạng thái nào của lỗ hổng trên máy chủ trung tâm cũng buộc các thiết bị thành viên phải tải dữ liệu về để đồng bộ hóa trạng thái mới nhất. Đáng chú ý, để đảm bảo tính an toàn dài hạn, trạng thái hợp lệ của một lỗ hổng có thể bị thách thức và tái phân xử nhiều lần trong suốt vòng đời của nó.

5 Phân tích

6 Kết luận

Tài liệu tham khảo